dreamDEX Perps Builder Bounty — reproducible testnet findings

43 independently reproducible issues (4 major, 39 normal) across docs, REST API, WebSocket feed, deployed app, bot kit and the perps contracts on Hideki (chain 50383). Each item is a separate Markdown file under **feedback/**, one issue per file, in the bounty template. Security-critical items were sent privately to security@dreamdex.io and are not in this repository, as the rules require.

How to reproduce

Item 48 ships a runnable script: **scripts/perp-oi-cap/** — `npm i && node audit.mjs`. It enumerates the 21 perp pools from PerpPoolFactory.getPerpPools() on chain 50383, reads maxOpenInterest and maxPositionSize per pool, and compares them against the trader docs table. It needs no wallet and no funds; every call is a read. The committed **run.log** is the captured output of the run the numbers in item 48 come from, including the block height and UTC timestamp. The script exits 1 when the mismatch is present — that non-zero exit is the finding, not a crash.

All other items are HTTP/JSON-RPC reproductions with the exact request and response inline in the file.

Scope note

Everything here was tested on testnet only, against the surfaces the docs and the program name. No mainnet system was touched, no third-party account was accessed, and no transaction was broadcast: findings that would have required funds or a funded wallet are marked as such or were not submitted.

Findings

#	Sev	Area	Title	File
2	normal	app	Public storage bucket listing enabled on cdn.dreamdex.io	02-cdn-bucket-listing.md
3	normal	app	CSP report-only header on app.testnet responses discloses internal dev/staging hosts	03-csp-report-only-leaks-internal-hosts.md
4	normal	API	Unauthenticated /metrics on api.testnet.dreamdex.io exposes internal route table and traffic stats	04-unauthenticated-metrics-endpoint.md
5	normal	API	State-changing POST /api/sponsor/warm accepts unauthenticated calls without rate limiting	05-sponsor-warm-unauthenticated-no-ratelimit.md
9	normal	docs	Market Data docs promise unknown symbols are silently skipped (empty []), live API returns 400 invalid_param	09-docs-unknown-symbol-400-not-silently-skipped.md
10	normal	docs	Market Data docs show comma-separated symbols returning [], live API parses both symbols (200 with data)	10-docs-comma-symbols-returns-data-not-empty.md
11	normal	API	WS operations with missing parameters return a REST-style 404 bad_request envelope instead of the documented invalid_parameters protocol error	11-ws-missing-param-returns-bad-request-envelope-not-invalid-parameters.md
12	normal	docs	Error Handling table documents error name invalid_interval, live API returns invalid_param for the same case	12-docs-invalid-interval-error-name-never-returned.md
13	normal	docs	Perps developer page documents chain 50383 while the HTTP API and the Contract Addresses page describe a different deployment on 50312, and neither page reconciles the two	13-perps-dev-page-points-to-chain-50383-while-api-runs-50312.md
14	normal	docs	Trader docs list 21 markets as BTC-PERP style names; the REST registry serves BASE:USDso and 404s every -PERP name, including markets whose base ticker it does carry	14-docs-21-perp-markets-perp-naming-vs-api-24-usdso-naming.md
15	normal	docs	HTTP API base-URL table sends testnet developers to stg.api.dreamdex.io; the perps API host api.testnet.dreamdex.io is undocumented anywhere	15-docs-testnet-base-url-points-to-stg-not-api-testnet.md
16	normal	API	NUL byte in the URL path returns 400 with empty body and no Error-Name header, violating the documented JSON error contract	16-nul-byte-path-returns-400-empty-violating-json-error-contract.md
17	normal	API	POST /v0/auth/login with a non-JSON Content-Type returns 500 internal_error and leaks a V8 exception string	17-login-non-json-content-type-500-leaks-v8-error.md
18	normal	API	Cancel and reduce prepares return calldata for an order id that does not exist	18-nonexistent-order-prepare-returns-calldata.md
19	normal	API	Leverage endpoint accepts values far above the documented per-market maximum while amount validation enforces the documented minimum	19-leverage-above-doc-max-accepted.md
20	normal	contracts	Nine of twenty-four perps pools have no stop-order registry while the docs advertise TP/SL on every market	20-pools-without-stop-order-registry.md
21	normal	contracts	Three pools sit outside the insurance-fund tier while the docs present the Insurance Fund as the standard ladder stage	21-pools-outside-insurance-tier-ladder.md

#	Sev	Area	Title	File
22	normal	contracts	Voucher distributor campaign is over with zero budget and claim() reverts while the docs still promise any address can claim 1,000 USDso	22-voucher-closed-while-docs-promise-claim.md
23	normal	contracts	One EOA owns every core perps contract and the shared pool beacon	23-single-owner-eoa-controls-perps-stack.md
24	normal	contracts	No perps contract has published source on the explorer	24-perps-contracts-source-unverified.md
26	normal	app	App redirects every visitor to a default market that does not exist in the API registry	26-app-default-landing-market-404.md
27	normal	app	App ships a 10m candle interval option that the candles endpoint and its own OpenAPI spec reject	27-app-offers-10m-candle-interval-api-rejects.md
28	normal	SDK	Bot kit ships with a default spot symbol that does not exist on the testnet it targets	28-bot-kit-shipped-defaults-target-nonexistent-spot-market.md
29	normal	API	Same malformed WebSocket frame returns two different validator messages on the two hosts the kit and docs call "testnet"	29-ws-two-hosts-two-validators-same-surface.md
30	normal	docs	One WebSocket feed is published under three different path shapes and the spec's own path variant with a trailing slash 404s	30-ws-path-shapes-spec-docs-slash.md
31	major	API	Numeric input overflows return 500/503 that leak internal library versions, package names and RPC method names	31-numeric-input-overflows-500-503-leak-internal-versions.md
32	normal	API	Order endpoints accept a 5MB JSON body, answer 500 instead of 413, and echo ~10MB back	32-no-request-body-size-limit-5mb-echo.md
33	normal	API	Known routes answer unsupported HTTP methods with 404 bad_request instead of 405	33-known-route-unsupported-method-returns-404-not-405.md
34	normal	API	PATCH with no body and no Content-Type reports invalid_amount instead of invalid_request_body	34-patch-missing-body-no-content-type-reports-invalid_amount.md
35	normal	API	Duplicate JSON keys in an order request are accepted silently (last-key-wins) and produce calldata	35-duplicate-json-keys-accepted-silently.md
36	normal	API	Query parameter validation is lax: limit accepts non-integer syntax and unknown/negative params are silently ignored	36-query-param-validation-lax-limit-hex-unknown-ignored.md
37	normal	API	404 envelopes use an undocumented error name and skip the Error-Name header the docs promise	37-404-envelope-uses-undocumented-name-and-omits-error-name-header.md
38	normal	API	Margin deposit ignores the currency parameter entirely while the market vault rejects the same values	38-margin-deposit-currency-param-ignored-vs-vault-rejection.md
39	normal	API	Rate limiting only trips after high-RPS bursts and every 429 advertises Retry-After: 1	39-rate-limit-threshold-and-fixed-retry-after.md
40	normal	API	gzip-compressed request body is rejected as invalid JSON instead of 415 Unsupported Media Type	40-gzip-request-body-rejected-as-json-not-415.md
41	normal	API	Stop-order endpoints return 404 on all 24 perp markets, including the 15 that do have a stop-order registry	41-perp-stop-orders-404-on-all-24-markets-including-15-with-a-registry.md
42	normal	API	WBTC and WETH are listed as both spot and perp under the identical symbol, and every write resolves to the spot market, leaving the perp side unaddressable	42-dual-listed-symbol-resolves-to-spot-so-perp-side-is-unaddressable.md
43	normal	API	builder/approve encodes any max fee the caller asks for, including values above the pool cap, producing a transaction the pool always reverts	43-approve-encodes-fee-above-pool-cap-producing-a-transaction-that-always-reverts.md
44	normal	docs	The spec declares the builder-fee ceilings as unbounded integers while every pool enforces a finite on-chain cap	44-spec-omits-maximum-on-builder-fee-fields-while-the-pool-enforces-one.md
45	normal	API	vault/approve answers HTTP 200 with a literal null body for a currency the same endpoint lists as accepted	45-vault-approve-returns-http-200-with-a-null-body-for-a-supported-currency.md
46	major	API	The spec's declared production WebSocket pathname 404s on production and staging while testnet accepts it, so spec-generated clients connect only on testnet	46-spec-production-ws-pathname-404s-only-testnet-accepts-it.md
47	major	docs	The testnet spec advertises nine subscribe channels and production recognises five, so four documented channels answer unknown_channel on mainnet	47-testnet-spec-nine-channels-production-recognises-five.md
48	major	docs	Trader docs open-interest cap is 2x or 4x the on-chain cap on 20 of 21 markets	48-docs-open-interest-cap-is-2x-or-4x-the-on-chain-cap.md